MODULE 24 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Responsible AI and AI Security Controls

Filter what goes in and comes out, control what agents may do and as whom, and put a human in front of decisions that matter.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 24 of 52

admin@sthithapragna.com

A model's instructions are **suggestions**. Controls that must hold belong **outside the model**, where a prompt cannot reach them.

Bedrock Guardrails policies

POLICY	CATCHES
Content filters	Hate, violence, sexual, misconduct, prompt attacks; text and images
Denied topics	Subjects you define, such as investment advice
Word filters	Profanity and custom words or phrases
Sensitive information	PII and custom regex: block or mask
Contextual grounding	Answers not supported by the source, or off the question
Automated Reasoning	Answers that contradict your written rules

ON THE EXAM

Prompt injection and jailbreak attempts are caught by the prompt attack category of content filters.

Applying guardrails everywhere

- **Inputs and outputs** are evaluated separately, each with its own action.
- **ApplyGuardrail API** works with any model, including ones outside Bedrock.
- **IAM condition** bedrock:GuardrailIdentifier forces a guardrail on calls.
- **Bedrock policies in Organizations** enforce a guardrail on every call, organisation wide.
- **Versions** pin a tested guardrail; update deliberately.

> ON THE EXAM
>
> A guardrail developers can skip is a suggestion. Enforce it with IAM, or across accounts with a Bedrock policy.

Contextual grounding or Automated Reasoning?

CONTEXTUAL GROUNDING

Is it supported by the source?

- Compares answer with retrieved passages
- Also scores relevance to the question
- Threshold you tune
- Suits RAG answers

AUTOMATED REASONING

Is it consistent with the rules?

- Rules built from your policy documents
- Formal logic, not probability
- Valid, invalid or satisfiable
- Suits eligibility and policy answers

THE TIEBREAKER

Verifiable against written rules, with an explanation of which rule failed: Automated Reasoning.

AgentCore Identity

DIRECTION	QUESTION	MECHANISM
Inbound	Who is calling the agent?	Validate tokens from Cognito, Okta, Entra ID
Workload	Which agent is this?	An agent identity, separate from any user
Outbound, as itself	Agent calls a service	OAuth client credentials or API key, vaulted
Outbound, for a user	Agent acts on a user's behalf	OAuth with user consent; tokens in the vault

ON THE EXAM

Act with the user's own permissions, not a shared super-account: outbound OAuth on the user's behalf.

Deciding what an agent may do

- **AgentCore Gateway** exposes tools to agents through one controlled entry point.
- **AgentCore Policy** checks every tool call at the gateway, deny by default.
- **Cedar rules** can test the user, the tool and its parameters, such as an amount.
- **Least privilege** for the agent's own IAM role, as for any workload.
- **Observability** traces every step, for audit and evaluation.

> ON THE EXAM
>
> A hard limit on a tool's parameters, enforced whatever the prompt: a policy at the gateway.

Which actions need a human?

TIER	EXAMPLES	APPROVAL
Read-only	Lookups, status queries	Autonomous
Low-risk writes	Routine updates	Single reviewer, or none
High-risk	Payments, deletion, external messages	Required; may need several reviewers

ON THE EXAM

Classify risk with deterministic rules. Never let the model decide whether it needs approval.

Which approval pattern?

STEP FUNCTIONS TASK TOKEN

Workflow waits for a reviewer

- Task emits a token and pauses
- Approval app calls SendTaskSuccess or Failure
- Waits up to a year; timeout and Catch
- Execution history records the decision

BEDROCK AGENTS CONFIRMATION

The end user approves

- User confirmation before a function runs
- Or return of control to the application
- Interactive, in the conversation
- Application handles timeouts

THE TIEBREAKER

A separate reviewer, possibly hours later, with escalation: Step Functions with a task token.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Block topics, mask PII, stop jailbreaks	Guardrails policies
Every account must use the guardrail	Bedrock policy in Organizations
Provably consistent with written rules	Automated Reasoning checks
Agent acts with the user's own access	AgentCore Identity, OAuth for the user
Hard limit on a tool, whatever the prompt	AgentCore Policy at the gateway
Separate reviewer, hours, escalation	Step Functions task token

ON THE EXAM

Every right answer here sits outside the model. A system prompt is never enough.

> Meridian Freight's customer chatbot on Amazon Bedrock must refuse harmful content, never give investment advice about freight futures, mask customers' phone numbers and email addresses in responses, and resist jailbreak attempts.
>
> Compliance requires these controls to hold regardless of how users phrase their requests.

What should the solutions architect implement?

A. A Bedrock guardrail with content filters including prompt attacks, a denied topic for investment advice, and sensitive information masking

B. System prompt instructions listing each rule

C. AWS WAF in front of the chatbot API

D. Amazon Comprehend PII detection in a Lambda function after each response

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Guardrail with three policies

Each requirement maps to a policy enforced outside the model.

B System prompt

Instructions a clever prompt can override.

C AWS WAF

Inspects HTTP traffic, not the meaning of a conversation.

D Comprehend in Lambda

Covers PII only, and is custom glue.

THE SIGNAL

Topics, harm, PII and jailbreaks, enforced independently: one guardrail, several policies.

Meridian Freight has 45 accounts where teams build generative AI features on Amazon Bedrock. An audit found some teams calling models without the company's approved guardrail.

The guardrail must apply to every model inference call in every account, without relying on teams to configure it.

What should the solutions architect implement?

A. A wiki page describing the guardrail standard

B. A Bedrock policy in AWS Organizations referencing the approved guardrail version, attached to the organisation root

C. An SCP that denies bedrock:InvokeModel entirely

D. A Config rule that reports applications without guardrails

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Wiki page

A convention, which the audit shows is not followed.

B Bedrock policy

Applies the guardrail to every inference call beneath the root.

C Deny InvokeModel

Stops all AI features instead of governing them.

D Config rule

Reports after the fact, if it can see the calls at all.

THE SIGNAL

Organisation-wide, without team configuration: a Bedrock policy in Organizations.

Meridian Freight's assistant answers customers' questions about whether a shipment qualifies for duty relief, based on a 60-page written customs policy.

Compliance wants each answer verified against the policy's rules, with an explanation of which rule an incorrect answer breaks.

Which control should the solutions architect add?

A Contextual grounding checks with a high threshold

B A denied topic for duty relief

C Setting the model temperature to zero

D Automated Reasoning checks built from the customs policy document

◆ PAUSE AND DECIDE

Which control should the solutions architect add?

A Contextual grounding

Scores support from passages; does not prove rule compliance.

B Denied topic

Blocks the very questions the assistant must answer.

C Temperature zero

More consistent, not more correct.

D Automated Reasoning

Formal rules from the policy; reports valid, invalid and the rule broken.

THE SIGNAL

Verified against written rules, with the failing rule named: Automated Reasoning checks.

> Meridian Freight is building a scheduling agent on AgentCore. Dispatchers sign in through the company's Okta. The agent must read and update each dispatcher's own calendar in a SaaS calendar service.
>
> The agent must only ever have the access that the signed-in dispatcher has, and must not store passwords.

What should the solutions architect implement?

A. AgentCore Identity with Okta as the inbound identity provider, and outbound OAuth on the user's behalf with tokens held in the token vault

B. A shared calendar service account whose credentials are in Secrets Manager

C. Each dispatcher's password stored encrypted in DynamoDB

D. An IAM role for the agent with full access to the calendar API

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A AgentCore Identity, user OAuth

Validates the dispatcher, then acts with their consented token only.

B Shared service account

The agent could reach every dispatcher's calendar.

C Stored passwords

Explicitly ruled out, and a serious liability.

D IAM role

IAM does not grant access inside a SaaS service.

THE SIGNAL

Act as the signed-in user, with no stored passwords: inbound IdP plus outbound OAuth for the user.

> Meridian Freight's customer-service agent can issue refunds through a refund tool exposed by AgentCore Gateway. Refunds above 500 dollars must never be issued by the agent, whatever a customer writes.
>
> The limit must be enforced deterministically and be reviewable by auditors.

What should the solutions architect implement?

A. A system prompt stating the 500 dollar limit

B. A guardrail denied topic for large refunds

C. An AgentCore Policy rule at the gateway denying refund tool calls with an amount above 500

D. Fine-tune the model on examples of refusing large refunds

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A System prompt

Probabilistic; a crafted message can override it.

B Denied topic

Judges conversation text, not the tool call's amount parameter.

C AgentCore Policy

Deterministic check of every tool call's parameters, outside the model.

D Fine-tuning

Makes refusal likelier, never certain.

THE SIGNAL

Deterministic, on a tool's parameters, auditable: a Cedar policy at the gateway.

Meridian Freight's operations agent can propose cancelling shipments. Cancellations worth more than 50,000 dollars must be approved by a duty manager, who may take several hours to respond.

If nobody responds within eight hours, the request must escalate to a second manager, and every decision must be recorded with the reviewer's identity.

What should the solutions architect implement?

A Bedrock Agents user confirmation in the chat session

B A Step Functions task using waitForTaskToken to an approval app, with an eight-hour timeout and a Catch that escalates

C A Lambda function that polls an inbox every minute

D An SNS email asking the manager to reply yes

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **User confirmation**

The approver is the chat user, not a separate manager hours later.

B **Task token workflow**

Pauses for hours, escalates on timeout, records the decision.

C **Polling Lambda**

Custom, fragile, and limited to 15 minutes per run.

D **Email reply**

No reliable identity, timeout or record.

THE SIGNAL

Separate approver, long wait, escalation, audit: Step Functions with a task token.

What to carry out of this module

- **Controls outside the model;** a system prompt is never the answer.
- **Guardrails** for content, topics, PII, prompt attacks, grounding and rules.
- **Enforce guardrails** with IAM, or organisation-wide with a Bedrock policy.
- **AgentCore Identity** for who; **AgentCore Policy** for what, per tool call.
- **Risk-tiered approval**; Step Functions task tokens for separate reviewers.

> ON THE EXAM
>
> Filter, identify, authorise, approve: four layers, none of them inside the prompt.